

ZAP by Checkmarx Scanning Report

Generated with [ZAP](#) on Fri 10 Oct 2025, at 13:04:20 ZAP Version:

2.16.1

ZAP by [Checkmarx](#)

Contents

- 1. [About this report](#)
 - 1. [Report description](#)
 - 2. [Report parameters](#)
- 2. [Summaries](#)
 - 1. [Alert counts by risk and confidence](#)
 - 2. [Alert counts by site and risk](#)
 - 3. [Alert counts by alert type](#)
- 3. [Alerts](#)
 - 1. [Risk=Medium, Confidence=High \(1\)](#)
 - 2. [Risk=Medium, Confidence=Medium \(1\)](#)
 - 3. [Risk=Medium, Confidence=Low \(1\)](#)
 - 4. [Risk=Low, Confidence=High \(1\)](#)
 - 5. [Risk=Low, Confidence=Medium \(3\)](#)
 - 6. [Risk=Informational, Confidence=Medium \(3\)](#)
 - 7. [Risk=Informational, Confidence=Low \(1\)](#)
- 4. [Appendix](#)
 - 1. [Alert types](#)

About this report

Report description

Insys report

Report parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- <https://localhost:5173>
- <https://localhost:5000>

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: High, Medium, Low, Informational

Excluded: None

Confidence levels

Included: User Confirmed, High, Medium, Low

Excluded: User Confirmed, High, Medium, Low, False Positive

Summaries

Alert counts by risk and confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				Total
		User Confirmed	High	Medium	Low	
Risk	High	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)
	Medium	0 (0.0%)	1 (9.1%)	1 (9.1%)	1 (9.1%)	3 (27.3%)
	Low	0 (0.0%)	1 (9.1%)	3 (27.3%)	0 (0.0%)	4 (36.4%)
	Informational	0 (0.0%)	0 (0.0%)	3 (27.3%)	1 (9.1%)	4 (36.4%)
	Total	0 (0.0%)	2 (18.2%)	7 (63.6%)	2 (18.2%)	11 (100%)

Alert counts by site and risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

		Risk			
		High (= High)	Medium (>= Medium)	Low (>= Low)	Informational (>= Informational)
Site	https://localhost:5173	0 (0)	1 (1)	0 (1)	1 (2)
	https://localhost:5000	0 (0)	2 (2)	4 (6)	3 (9)

Alert counts by alert type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
Content Security Policy (CSP) Header Not Set	Medium	12 (109.1%)
Hidden File Found	Medium	4 (36.4%)
Missing Anti-clickjacking Header	Medium	12 (109.1%)
Cookie without SameSite Attribute	Low	3 (27.3%)
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low	2 (18.2%)
Strict-Transport-Security Header Not Set	Low	15 (136.4%)
X-Content-Type-Options Header Missing	Low	15 (136.4%)
Modern Web Application	Informational	10 (90.9%)
Re-examine Cache-control Directives	Informational	12 (109.1%)
Session Management Response Identified	Informational	6 (54.5%)
User Agent Fuzzer	Informational	14 (127.3%)
Total		11

Alerts

1. Risk=Medium, Confidence=High (1)

1. https://localhost:5000 (1)

1. [Content Security Policy \(CSP\) Header Not Set](#) (1)

► GET https://localhost:5000

2. Risk=Medium, Confidence=Medium (1)

1. https://localhost:5000 (1)

1. [Missing Anti-clickjacking Header](#) (1)

► GET https://localhost:5000

3. Risk=Medium, Confidence=Low (1)

1. https://localhost:5173 (1)

1. [Hidden File Found](#) (1)

► GET https://localhost:5173/.hg

4. Risk=Low, Confidence=High (1)

1. https://localhost:5000 (1)

1. [Strict-Transport-Security Header Not Set](#) (1)

► GET https://localhost:5000

5. Risk=Low, Confidence=Medium (3)

1. https://localhost:5000 (3)

1. [Cookie without SameSite Attribute](#) (1)

► GET https://localhost:5000/robots.txt

2. [Server Leaks Information via "X-Powered-By" HTTP Response Header Field\(s\)](#) (1)

► GET https://localhost:5000

3. [X-Content-Type-Options Header Missing](#) (1)

► GET https://localhost:5000

6. Risk=Informational, Confidence=Medium (3)

1. https://localhost:5173 (1)

1. [Modern Web Application](#) (1)

► GET https://localhost:5173/

2. https://localhost:5000 (2)

1. [Session Management Response Identified](#) (1)

► GET https://localhost:5000/robots.txt

2. [User Agent Fuzzer](#) (1)

► GET https://localhost:5000

7. Risk=Informational, Confidence=Low (1)

1. <https://localhost:5000> (1)

1. [Re-examine Cache-control Directives](#) (1)

► GET <https://localhost:5000>

Appendix

Alert types

This section contains additional information on the types of alerts in the report.

1. Content Security Policy (CSP) Header Not Set

Source raised by a passive scanner ([Content Security Policy \(CSP\) Header Not Set](#))

CWE ID [693](#)

WASC ID 15

Reference

1. https://developer.mozilla.org/en-US/docs/Web/Security/CSP/Introducing_Content_Security_Policy
2. https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
3. <https://www.w3.org/TR/CSP/>
4. <https://w3c.github.io/webappsec-csp/>
5. <https://web.dev/articles/csp>
6. <https://caniuse.com/#feat=contentsecuritypolicy>
7. <https://content-security-policy.com/>

2. Hidden File Found

Source raised by an active scanner ([Hidden File Finder](#))

CWE ID [538](#)

WASC ID 13

Reference

1. <https://blog.hboeck.de/archives/892-Introducing-Snallygaster-a-Tool-to-Scan-for-Secrets-on-Web-Servers.html>

3. Missing Anti-clickjacking Header

Source raised by a passive scanner ([Anti-clickjacking Header](#))

CWE ID [1021](#)

WASC ID 15

Reference

1. <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options>

4. Cookie without SameSite Attribute

Source raised by a passive scanner ([Cookie without SameSite Attribute](#))

CWE ID [1275](#)

WASC ID 13

Reference

1. <https://tools.ietf.org/html/draft-ietf-httpbis-cookie-same-site>

5. Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)

Source raised by a passive scanner ([Server Leaks Information via "X-Powered-By" HTTP Response Header Field\(s\)](#))

CWE ID [497](#)

WASC ID 13

Reference

1. https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework
2. <https://www.troyhunt.com/2012/02/shhh-dont-let-your-response-headers.html>

6. Strict-Transport-Security Header Not Set

Source raised by a passive scanner ([Strict-Transport-Security Header](#))

CWE ID [319](#)

WASC ID 15

Reference

1. https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html
2. <https://owasp.org/www-community/Security-Headers>

- Reference**
3. https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security
 4. <https://caniuse.com/stricttransportsecurity>
 5. <https://datatracker.ietf.org/doc/html/rfc6797>

7. X-Content-Type-Options Header Missing

Source raised by a passive scanner ([X-Content-Type-Options Header Missing](#))

CWE ID [693](#)

WASC ID 15

- Reference**
1. [https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941\(v=vs.85\)](https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85))
 2. <https://owasp.org/www-community/Security-Headers>

8. Modern Web Application

Source raised by a passive scanner ([Modern Web Application](#))

9. Re-examine Cache-control Directives

Source raised by a passive scanner ([Re-examine Cache-control Directives](#))

CWE ID [525](#)

WASC ID 13

- Reference**
1. https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching
 2. <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Cache-Control>
 3. <https://grayduck.mn/2021/09/13/cache-control-recommendations/>

10. Session Management Response Identified

Source raised by a passive scanner ([Session Management Response Identified](#))

- Reference**
1. <https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id>

11. User Agent Fuzzer

Source raised by an active scanner ([User Agent Fuzzer](#))

- Reference**
1. <https://owasp.org/wstg>